攻撃事例に基づくセキュリティインシデント対応エージェントのプランニング能力評価フレームワーク

川口 雄己[1,a)]　山中 友貴[1,b)]　樋渡 淳也[1,c)]　田村 颯樹[1,d)]

概要：近年, インシデント対応を支援・自動化する手段として, 大規模言語モデル（LLM）を活用する研究が進められている. しかしながら多くの従来研究では, 実験環境やインシデントシナリオが限定的で,LLM によるプランニング能力を十分に評価できていない.
そこで本論文では,LLM によるインシデント対応のプランニング能力を, 公開レポートや組織内で蓄積された多様な攻撃事例をもとに低コストに評価可能なフレームワークを提案する. このフレームワークでは,MITRE ATT&CK などのナレッジベースを使い, 情報を整理し, 攻撃事例の全体像から有効な対応及び調査計画を生成する. そして, この調査計画を切り出すことで各時点の観測情報をもとに各状況に対する調査計画を立案させる評価タスクを生成する.
実験では, 生成されたタスクを検証し, フレームワークによって実際にエージェントの計画傾向を評価した. その結果, エージェントに対し, 有効な調査計画を生成できるものの, 最小調査数となる調査計画を生成しない傾向があるなどの傾向評価が可能であることを示した.

キーワード：CSS 2026, インシデント対応, セキュリティエージェント, エージェントプランニング, 評価フレームワーク

A Case-Based Framework for Evaluating the Planning Capability of Security Incident Response Agents

Yuki Kawaguchi[1,a)]　Yuuki Yamanaka[1,b)]　Junya Hiwatari[1,c)]　Satsuki Tamura[1,d)]

Abstract: Recent studies have explored large language models (LLMs) for supporting and automating incident response. However, many use limited experimental settings and incident scenarios, preventing sufficient evaluation of LLM planning capabilities.
We propose a low-cost framework for evaluating LLM incident response planning using diverse attack cases from public reports and organizational records. Using knowledge bases such as MITRE ATT&CK, the framework organizes attack information, reconstructs each case, and generates effective response and investigation plans. It then derives evaluation tasks from the investigation plans, requiring agents to plan investigations for each situation based on observations available at each point in time.
Experiments validated the generated tasks and used the framework to evaluate agent planning tendencies. The results show that the framework can reveal tendencies such as generating effective investigation plans without minimizing the number of investigation steps.

Keywords: CSS 2026, Incident Response, Security Agent, Agent Planning, Evaluation Framework

[1] NTT 社会情報研究所
NTT Social Informatics Laboratories
[a)] yki.kawaguchi@ntt.com
[b)] yuuki.yamanaka@ntt.com
[c)] jun.hiwatari@ntt.com
[d)] satsuki.tamura@ntt.com

1. はじめに

サイバーセキュリティにおけるデジタルフォレンジックやインシデント対応においては, 攻撃の全体像が分からな

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

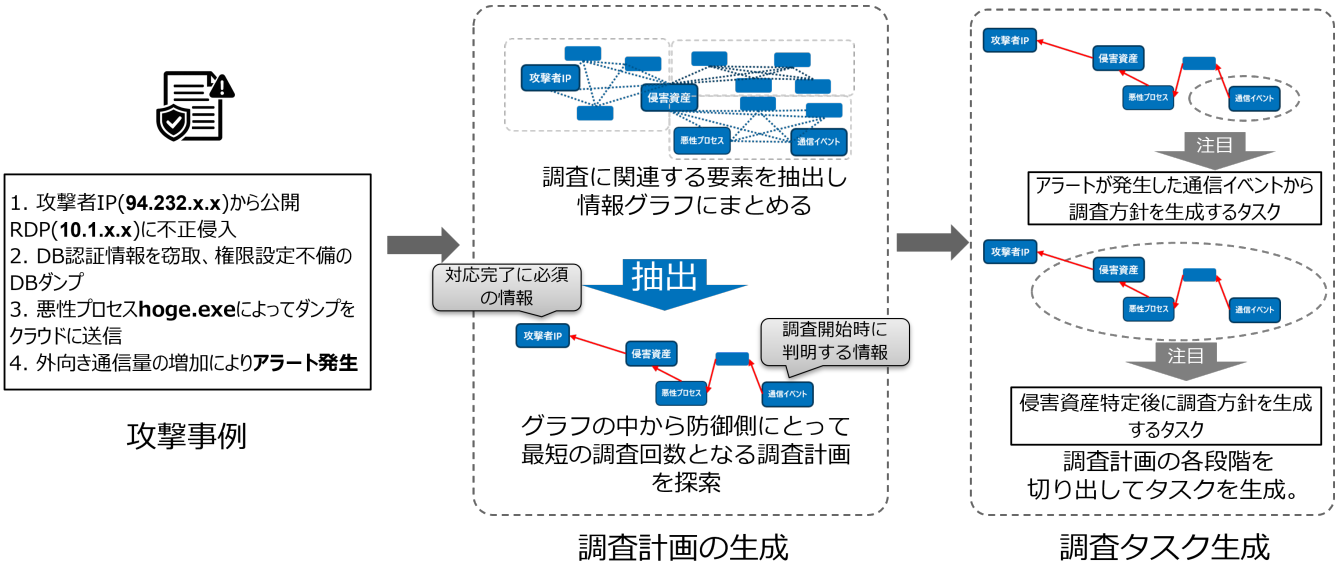


図 1: 評価タスク生成フレームワークの概観

い状態でインシデント収束に必要な情報を収集しなければならない. 例えばインシデント対応における調査では, 事態終結に向けて攻撃者の侵入元や被害端末といった情報を入手していくが, これらの情報は対応開始時には部分的にしか得られず, 対応を進めるにつれて段階的に全体像が判明していくことが多い. さらに, 被害を最小限に抑えるためには迅速に攻撃者の行動を抑制する必要があり, 時間的制約も発生する. これらのことからセキュリティインシデント対応においては, どの情報を手掛かりにして, 次にどの情報を入手すべきかという方針を状況に応じてプランニングすることが重要となる. 本研究ではこの情報探索に関するプランニングに焦点を当てる.

近年, こうしたプランニングを含めたインシデント対応を支援・自動化する手段として, 大規模言語モデル（LLM）を活用する研究が進められている [1]. 従来研究では動的にチェックリストを更新していくことでプランニングを行うものや [2], インシデント対応の完了に必要な状態を定義し, 複数生成した対応計画の中から最も迅速に対応可能なものを選ぶことでプランニング [3][4] を行うものなどが存在する. これらの従来研究ではセキュリティ対応の訓練プラットフォームや仮想環境に攻撃を行ったログなどを使い評価が行われている. しかしながら, これらの研究では特定の環境下における少数パターンのインシデントシナリオについてのみの評価しか行われておらず, 多様な状況におけるプランニング能力の評価は限定的である. また評価のバリエーションを増やそうとしても, 環境自体や攻撃シナリオを手動で増やす必要があるため, コストが高い.

そこで本論文では具体的な調査時のログクエリ生成といった能力ではなく, 情報探索の計画能力に絞り込んで評価を行うことで, 低コストでバリエーションを増やすことが可能な評価方法を提案する. 本研究では, 公開レポートや組織内で蓄積された攻撃事例に着目する. 攻撃事例には攻撃に関係するマルウェアやドメインの IoC, 明示されていないが暗黙的に示される被害端末の情報など, 調査の手掛かりとなる情報が含まれている. そのため, これらの情報と情報間の関係を評価可能な形式に構造化できれば, 固定された少数のシナリオに依存せず, 多様な攻撃事例を用いてプランニング能力を評価することが可能となる. そこで本論文では, サイバーセキュリティにおける AI エージェントによるインシデント対応のプランニング能力を, 多様な攻撃事例をもとに評価可能なフレームワークを提案する. 図 1 にフレームワークの概観を示す.

本論文の主な貢献は以下の通り.

- インシデント対応のプランニング能力を, 既知集合から対応に必要な終点へ至る, 取得数最小の調査計画を構成する問題として定式化した.
- 攻撃事例中の情報を調査要素として抽出・補完し, その関係を情報グラフとして共通形式に構造化する枠組みを示した.
- 多様な攻撃事例からプランニング能力の評価タスクを生成するため, 情報グラフから取得数最小の調査計画を抽出し, 計画の各時点をタスク化する方法を提案した.
- 生成したタスクにより,LLM エージェントが有効な調査計画を生成できる一方, 最小調査数となる計画を生成しないといった傾向を評価可能であることを示した.

2. 従来研究

本章では AI エージェントを用いたインシデント対応の研究において, どのようなプランニングの試みが行われ, プランニング能力がどのように評価されてきたか述べる.

© 2026 Information Processing Society of Japan

Lin らの研究 [2] では,AI エージェントが動的な対応チェックリストを作成することで,IR のプランニングを実施している. 具体的にはひな型として用意されたチェックリストのテンプレートについて,LLM が状況に応じて具体化を行い, 実行結果をもとにこのチェックリストの項目をさらに細分化するなどしてコントロールする. 評価方法としては TryHackMe などの仮想訓練プラットフォームが用いられ, プラットフォーム上のタスク完遂率で評価されている.

Hammer らの研究 [3] や Gao らの研究 [4] ではインシデント対応の状態を,「攻撃を停止できているか」,「攻撃範囲を把握できているか」,「証拠を保全できているか」といった二値の 6 次元ベクトルで表現し, 生成された候補アクションがこれらのベクトルをどのように遷移させるかを評価することでプランニングを行う. 具体的には現在の状況やログから複数の候補アクションを生成し, 再帰的にベクトル遷移を行うシミュレーションを行うことで, 複数の復旧計画を生成し, この中で最も復旧時間が短くなると推定されたものを選択する. 評価方法としては公開実ログデータセットや仮想環境で作成されたアラートを対象にシステムを適用し, 復旧まで必要なステップ数を Recovery time としてその評価を行った.

Tellache らの研究 [5] では,SIEM アラートをオンライン脅威情報データベース VirusTotal の情報で補強し, それをもとに関連情報をコサイン類似度ベースで検索し, 具体的に想定される攻撃の目的や動作を絞り込み, それに対する対応をすることでプランニングを実施する. 評価では, 実環境アラートと, 仮想環境におけるアラートデータを作成し, 関連情報の結び付けや対応の妥当性を評価している.

これらのように従来研究ではチェックリストや状態ベクトルといったものを使いインシデントの完了状態を表現し, プランニングを行っている. また評価においては仮想環境が多く用いられており, 最新の攻撃に対する評価を実施したい場合のコストが高い状態となっている.

こうした問題を解消するために, 従来研究におけるプランニングは判明した情報をもとに行うものであるが, 本研究では攻撃の全体像が分かっている状態において Tellache らのような脅威情報のエンリッチング,Hammer らや Gao らのようなインシデントの完了状態の管理といった発想を応用することで, 攻撃事例から有効な対応の全体像を作成することができると仮定し, この全体像を使うことでプランニング能力を測ることを提案する. これによって従来研究における仮想環境の整備や実ログの収集といった評価のためのコストが高くなってしまう問題を解決し, 様々な状況での評価を容易にすることを目的とする.

3. フレームワーク構成

本フレームワークは攻撃事例をもとに防御側がどのような調査によって対応を実施できるかを示す調査計画を抽出する調査計画抽出部と, この調査計画を使って AI エージェント向けのインシデント対応プランニング能力評価タスクを生成するタスク生成部に分かれている. 本フレームワークでは Hammer ら [3] の研究におけるプラン選択にみられるようにアクションの数の少なさによってプランの有効性を測る.

調査計画抽出部では攻撃事例を「調査要素」という情報単位で分析し, その後調査要素を用いて攻撃事例に登場する情報を整理することで情報グラフを作成する. 情報グラフは攻撃における調査要素のつながりをエッジとして持つ無向グラフである. 次にこの無向グラフから, 取得する調査要素数が最小となる調査計画を抽出する. ただし, 攻撃事例における情報のつながりが必ずしも防御側にとって調査可能とは限らないため, 候補計画に含まれる調査方向について調査可能性を判定する. 取得数の少ない候補から順にこの判定を行うことで, 取得数最小の調査計画を抽出する. 図 2 に調査計画抽出部の動作の全体像を示す.

3.1 情報グラフと探索境界の構成

3.1.1 調査要素の抽出と情報グラフの作成

本研究では IP アドレス, ドメイン名, ファイルハッシュなどの IoC に加えて, 被害端末, ユーザアカウント, プロセス, ファイル, 利用サービス, ログ記録など, インシデント調査において個別に特定あるいは参照される対象と, その識別情報を「調査要素」と定義する.

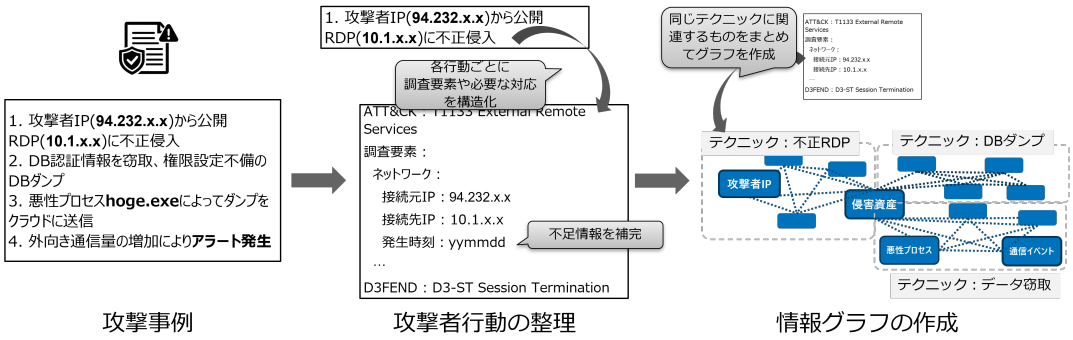
調査要素の抽出においては, まず攻撃事例を MITRE ATT&CK[6] のテクニックベースで整理し, それぞれのテクニックごとに関連する要素をまとめていくことで抽出する. なお,MITRE ATT&CK は, 実際の攻撃事例に基づき, 攻撃者の行動を戦術・テクニックとして体系化した知識ベースである. ここで ATT&CK におけるテクニックとは, 攻撃者が目的を達成するために用いる具体的な手法を示す用語である.

なお, 調査要素の範囲は MITRE ATT&CK のデータソースおよびデータコンポーネントを参考に定めた.ATT&CK のデータソースは, 攻撃者の振る舞いを検知する際に情報を収集する対象を分類したものであり, データコンポーネントは, それらの対象から観測される具体的な情報を表す.

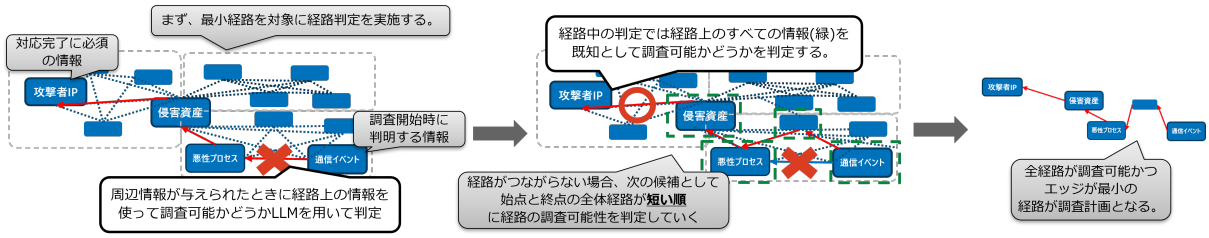
また, 組織内部の情報は, 事例中に具体値が記載されず, その存在のみが暗黙的に示される場合がある. そこで, 攻撃事例に明示された対象または事象から直接推定できる場合に限り, 付録の表 A·1 に示す情報項目を具体値が未特定の調査要素として補完する.

こうした調査要素を用いて, 攻撃事例に登場する情報を整理した情報グラフを作成する. 調査要素がノードとなり, エッジは同じテクニックで使われる他の調査要素とのつながりを示す. 情報グラフでは同じテクニックに関連する調査要素同士は密結合になり, それらのクラスタをテクニッ

© 2026 Information Processing Society of Japan



(a) 調査要素の抽出と情報グラフの作成



(b) 調査計画の生成

図 2: 調査計画抽出部

クを跨ぐ調査要素がつなぐ構成のグラフとなる.

3.1.2 調査の始点及び終点の決定

本研究では調査計画を, 特定の攻撃事例に対して防御側が対応を行う際に必要な封じ込めや根絶のための情報を, どのような順序で入手するかを表す概念として定義する. なお, インシデント対応においては封じ込めは被害拡大の抑止, 根絶は侵害原因や攻撃者の残存要因の除去を目的とする防御側の対応を指す.

ここではまず, 調査計画の終点を定める準備として, 攻撃事例で使われたテクニックの集合に対し,MITRE の D3FEND[7] を用いて封じ込めと根絶が必要なテクニックとその対応方法を決定する. なお,MITRE D3FEND は, サイバー防御の対抗手法と, その対象となるデジタルアーティファクトの関係を体系化した知識グラフである.ATT&CK の攻撃テクニックとの関連も記述され, 防御策の検討や分析に利用されている. 本研究では D3FEND の isolate と evict の防御テクニックをそれぞれ封じ込めと根絶に対応するものとみなす. ただし, すべての攻撃テクニックに D3FEND の封じ込めと根絶が紐づくわけではなく, 例えば単なる感染を広げる前の下調べのようなテクニックには本研究で対象とする意味での封じ込めは存在しない. この D3FEND の防御テクニックに必要な調査要素をテクニックに紐づく調査要素の中から決定し, これが対応終結に必要な情報, すなわち調査計画の終点となる. この終点は 1 つの D3FEND 防御テクニックに対して複数紐づくことがあり, 攻撃事例全体では多数の終点が発生しうる. 一つの対応目標に対して複数の終点が定まる具体例を付録の表 A·2 に示す.

続いて調査計画の始点を決定する. 調査計画の始点は攻撃テクニックの検知時に防御側が直接取得可能な調査要素の集合として定義する. ただし, 攻撃事例では基本的に成功した攻撃について触れられており検知の概念がない場合も多い. そこで, 攻撃事例に含まれる各 ATT&CK テクニックについて,ATT&CK に記載されている Detection Strategy と突き合わせ, 当該テクニックが検知された状況を設定する. ATT&CK の Detection Strategy には, 対象テクニックを検知するための方針が示されており, 各 Detection Strategy には Analytics が含まれている. そして各 Analytics には, 検知に用いるデータコンポーネントやログソース, ならびに検知対象となる振る舞いが記述されている.

本研究では, このように記述と攻撃事例中の調査要素を対応付けることで, 検知時に直接取得できる調査要素を決定し, 調査計画の始点とする. 検知対象, 検知方針, 攻撃事例中の情報, および始点集合の対応例を付録の表 A·2 に示す. なお, 一つの Detection Strategy は複数の調査要素を検知条件として含みうるため, 始点は調査要素の集合となる. また攻撃事例には複数のテクニックが含まれ, それぞれに Detection Strategy が対応するが, 実際のインシデント対応では対応の開始時点では, すべてのテクニックが同時に検知された状態から調査が始まるわけではない. そこで本研究では,Detection Strategy ごとに得られる調査要素の集合を一つの検知事象とみなし, 始点集合を検知事象ごとに定める.

© 2026 Information Processing Society of Japan

3.2 調査計画の抽出

3.2.1 調査可能性と探索問題

3.1.2 項で定めた始点から終点へ至るまでに, 調査要素を取得する順序を調査計画とする. 情報グラフを $G = (V, E)$ と表す. このグラフのエッジは攻撃事例中の関係を表すだけであり, 一方の調査要素を手掛かりとして他方を取得できることまでは保証しない. そこで, 無向エッジ $\{u, v\} \in E$ に対して調査方向 $u \to v$ あるいは $v \to u$ を考え, 調査可能性を LLM で判定する.

$\mathrm{Judge}(u, v)$ は, 既知の調査要素 u を手掛かりとして, 防御側が実行可能な調査により v を取得できるかを返す. 調査可能な場合は,u 以外に必要となる調査要素の集合 $\sup(u, v)$ も得る.u だけで v を取得できる場合, この前提集合は空である. 例えば, イベント ID が既知であり, そのイベントの src_ip から攻撃者 IP を特定できる場合, イベント ID から攻撃者 IP への方向は調査可能と判定される.

既知集合 K から調査要素 v を取得できる条件を次のように表す.

$$\begin{aligned}\mathrm{Acquirable}(v \mid K) \quad \Longleftrightarrow \quad & \exists u \in K :\ \{u, v\} \in E \\ & \wedge\ \mathrm{Judge}(u, v) = \mathrm{true} \\ & \wedge\ \sup(u, v) \subseteq K.\end{aligned}$$

この条件では, 調査の手掛かり u と調査に必要な前提情報がいずれも既知でなければならないことを示している. また, 手掛かりは直前に取得した要素に限らず, その時点の既知集合から選択できる. これはインシデント対応においては直前の手掛かりだけではなく, それまでに明らかにした情報すべてが使えることを反映している.

調査計画の抽出を, 既知集合を状態とする探索問題として定式化する. 状態 K において未知の調査要素 v が取得可能であるとき, 次の状態へ遷移する.

$$K \longrightarrow K \cup \{v\} \quad \Longleftrightarrow \quad v \notin K \ \wedge\ \mathrm{Acquirable}(v \mid K).$$

初期状態は検知事象から得られる始点集合 S であり, 終点 t を含む既知集合を目標状態とする. 初期状態から目標状態へ至る状態遷移を

$$S = K_0 \longrightarrow K_1 \longrightarrow \cdots \longrightarrow K_m, \qquad t \in K_m$$

と表す. 各遷移で新たに取得する調査要素の列 $\Pi = (v_1, \ldots, v_m)$ を調査計画とする. 終点が初期状態に含まれる場合は遷移を必要とせず,$\Pi = ()$ とする.

本研究では, 目標状態へ至る遷移回数 m が最小の調査計画をすべて正解とする. 同じ遷移回数で目標状態へ至る列が複数ある場合は, 正解となる計画も複数となる. 始点から終点への取得関係を付録の図 A·1 に, 各既知集合における取得要素, 手掛かり, および前提集合を付録の表 A·3 に示す.

3.2.2 候補計画の生成と確認

状態遷移の可否は現在の既知集合と前提集合に依存するため, 情報グラフの頂点だけを状態とする通常の最短経路探索は利用できない. そこで, 既知集合を探索状態として, 調査要素を一つずつ追加する網羅的な探索を行う. この探索は検知事象と終点の組ごとに行う.

すべての調査方向を先に判定すると, 最小計画に現れない関係にも LLM による判定が必要となる. そのため, まず情報グラフ上の関係から取得数の少ない候補計画を求め, 候補中の各取得が実際に可能かを順に確認する. 確認結果は,「そのまま取得できる」,「追加の前提が必要となる」,「取得できない」のいずれかとなる. 前提が判明した場合は取得条件を追加し, 取得できない場合はその方向を除外して候補を再探索する.

判定によって候補が短くなることはなく, そのまま成立するか, 条件が増えるか, あるいは候補から除外される. したがって, 取得数が最も少ない候補について必要な調査方向をすべて確認できた時点で, その候補を最小の調査計画として確定する. 探索アルゴリズムの詳細を付録 A.3 に示す.

こうして得られる最小性は, 取得する調査要素の個数に関するものである. 実際の調査にかかる時間は各調査ごとに異なるため, 突出して時間がかかる調査が含まれる場合など, 所要時間の観点では必ずしも最小にならないことに注意が必要である.

3.3 調査計画を用いたタスク生成

タスク生成部では, 調査計画を用いて,AI エージェントがインシデント対応に必要な情報を得るための調査方針を計画できるかを評価するタスクを生成する. インシデント対応の開始時点では, 防御側が把握可能な情報は, 初期検知によって得られた情報に限られ, その後の調査によって順次情報が得られていく. そこで本タスクでは,3.2 節で定義した調査計画に基づいて, 各時点で既に判明している情報を決定し, タスクを生成する. 具体的には, 既知集合 K_j と, 集合内の要素間で確認された関係を攻撃事例の記述に対応付け, 今何がわかっていて, どこまで完了しているかを示す現在のインシデント状況を構成する. そして, 同一の調査計画から, 調査段階の異なる複数のタスクを生成する. 既知集合の更新と各時点の正解の具体例を付録の表 A·3 に示す.

タスクでは, 状況に加えてその調査がどういった封じ込めや根絶のために行われるのかを示す対応目標を提示する. これは同一状況でも複数の目的がありうるため, 回答の自由度を制約し, 評価をしやすくする目的である. そして AI エージェントは, 提示された状況と対応目標をもとに, 目標に必要な情報をできるだけ少ない調査で明らかにするため,N 手分の調査方針を回答する. 回答では各手について, 調査の手掛かりとして利用する既知の情報, その情報を用いて確認する内容, 新たに明らかにしようとする情報, およびその情報を明らかにする目的を明示させる. これにより, 単に次に取得すべき情報を推測するのではなく, 現在の情

© 2026 Information Processing Society of Japan

表 1: 調査方針生成タスクの構成

項目	内容
入力	検知された事象, 現在までに判明している事実, および対応目標
要求	現在までに判明している情報を用いて, 対応目標に必要な情報をできるだけ少ない調査で明らかにするための調査方針を 2 手示す
出力	各手について, 調査に利用する情報, 調査方針, 新たに明らかにしようとする情報, およびその情報を明らかにする目的

報をどのように用いて次の情報へ到達するかを計画できるかを評価する. エージェントに提示するタスクの具体例を付録の表 A·4 に示す. なお,N を大きくする場合, 必要となる計画の深さが増大し, 複雑な事例でなければタスク生成ができなくなる.

表 1 に, 本タスクで提示する情報と求める回答を示す.

対応目標には,3.1.2 項で終点を定める際に用いた D3FEND の防御テクニックを, 端末のネットワーク隔離やアカウントのロックといった個々の対処の粒度で提示し, あわせてその対処が対象とする攻撃テクニックを示す. すなわち対応目標は対処と攻撃テクニックの組である. ここで, ある対処と攻撃テクニックの組を目標として提示できるのは, そのテクニックの活動が行われたと判断できる調査要素が一つ以上既知集合 K_j に含まれる場合に限る. これは, 当該テクニックが起きたと分からない段階でその対処を目標として与えても, 防御側にはその対処を状況から選択できないためである. ここでいう判断できる調査要素とは,D3FEND のアーティファクトによって定まるテクニックの活動が残した痕跡や生成した対象を示し,D3FEND の記述との一致判定には LLM を用いる.

そのため, グラフ上の初期段階から生成されるタスクでは, 調査起点の検知によって痕跡が得られているテクニックへの対処が目標となり, 調査が進んで他のテクニックの痕跡が既知集合に入るにつれ, それらへの対処が目標に加わる.

なお, 長さが最小の調査計画は同率のものが複数存在しうるため, ある段階で次に取得すべき調査要素も複数となりうる. そのため, 正解は常に 1:1 ではない.

また, 当該の対応目標に定まった終点のいずれについても残る取得が N 未満となる段階は,N 手を問えないためタスクとしない. 少なくとも一つの終点が N 手以上を要する段階をタスクとする.

なお, 本フレームワークにおけるタスクが対象とするのは調査方針の計画能力であり, 具体的なコマンドや製品操作などの詳細な調査手順そのものではない点に注意する. 回答の評価方法は 4.3 節で述べる.

4. 実験

本章では, 提案フレームワークを実際の攻撃事例に適用し, 評価タスクを生成できることを確認する. 続いて生成されたタスクの妥当性を確認し, そのタスクを用いてエージェントの情報探索方針を評価する.

4.1 実験設定

フレームワークでは N 手先までの計画を評価する. 今回は計画長を $N = 2$ とした.N が大きくなるほど複雑な状況が必要となり, 条件を満たすタスク数は減少する.

対象とする攻撃事例には, 公開されている攻撃レポート 3 件を用いた. 事例 1 は公共機関へのドメイン侵害 [8], 事例 2 は Apache ActiveMQ の脆弱性悪用に始まる LockBit ランサムウェアの被害 [9], 事例 3 は Lynx ランサムウェアの被害 [10] を扱った報告である. 事例の選定では, 含まれる ATT&CK テクニックが互いに異なるものを選定している. 知識ベースには ATT&CK 19.1 と,2026 年 3 月時点の D3FEND を用いた.

LLM を用いるのは, 調査要素の抽出から状況文の生成までのフレームワーク側の処理, 評価対象のエージェント, および回答と調査要素の同定を含む評価側の判定の 3 か所である. フレームワーク側の処理と評価対象のエージェントには GPT-5.6 Terra を, 評価時の判定にはより高性能とされる GPT-5.6 Sol を用い,temperature を 0 とした.

4.2 生成結果

表 2 に, 事例ごとの生成結果を示す. また, トークン消費について今回の実験では 1 事例あたり 50 万〜900 万トークンが消費されており, 事例ごとのばらつきが大きかった. 具体的に生成されたタスク内容は付録の表 A·4 に示した. テクニック数と調査要素数は事例の複雑さを表す. 組数は検知事象で判明する調査要素と終点となる調査要素の組み合わせの数を示すもので, 計画探索のコストに直結する. これは使用されたテクニックがどれだけの調査要素を対応に必要とするか, 検知に必要とするかによって主に決まる. 経路がつながる組数は, 始点, 終点, および前提となる調査要素が互いにつながる組数である.

事例に含まれるテクニックのうち,D3FEND の対処が対応付けられるのは順に 12 件,7 件,11 件であり, そのうち終点となる調査要素が事例中にあるのは 9 件,4 件,4 件であった. 最終的にタスクが生成されたテクニックはいずれの事例でも 1 件であった. これらと生成されたタスク数のばらつきについては 5.1 節で詳しく述べる.

© 2026 Information Processing Society of Japan

表 2: 攻撃事例ごとの評価タスク生成結果

項目	事例 1	事例 2	事例 3
抽出された事例の規模			
テクニック数	16	17	16
調査要素数	29	24	41
組数	150	30	99
経路がつながる組数	102	30	99
タスク関連テクニック種別	1	1	1
生成されたタスク数	104	8	3

4.3 エージェントの評価

続いて生成した評価タスクを用いてエージェントを評価した. 評価では LLM に各タスクへの回答を生成させる. 回答は 2 手分あり, それぞれ調査に利用する情報, 調査方針, 新たに明らかにしようとする情報, およびその情報を明らかにする目的の 4 項目からなる. エージェントに与えるのは, 検知された事象, その時点までに判明している状況, 対応目標, および問いになっており, 後続の情報が入り込まないように注意した. また, 本研究では, 少ない調査で目標に到達する計画をより良い計画とみなしており, 評価基準にもそれを反映させる.

評価は短い経路の調査になっているかを問う最小性とその実行可能性, そして経路に依存しない調査妥当性の 3 項目で実施した.

(1) 調査妥当性. 新たに明らかにしようとした情報が, 対応目標の実施のための情報であること.
(2) 最小性. 新たに明らかにしようとする情報が, 正解として与えた組のいずれかの調査要素と一致すること.
(3) 最小調査の実行可能性. 最小性を満たす調査に利用する情報が, いずれもその時点の既知集合に含まれること.

最小性とその実行可能性は, 抽出された調査計画とそれを切り出した既知集合との照合で決定される. 調査妥当性は調査計画とは独立に, 調査自体が対応目標に沿ったものかどうかを評価用 LLM に二値評価させたものになっている. 計画の最小性は今回のタスクにおいて生成された 2 手先までの調査がどちらも最小性を満たすかどうかを示している. 回答は自由記述であるため, 明らかにしようとした情報が正解の調査要素と一致するかの判定が必要となる. この判定は, 正解の調査要素ごとに, その名称, 説明, 役割, および既知集合に含まれる関連要素を与え, 評価用 LLM に二値判定させた.

表 3 に評価結果を示す. 調査妥当性を満たしたのは 115 件中 101 件であるのに対し, 最小性を満たしたのは 13 件,3 つをすべて満たしたのは 6 件であった. 調査妥当性を満たしながら最小性を満たさない回答が 90 件存在した. つまり 101 件の回答が目標に対して有効な調査ではあるが, そのうち 90 件が調査手順としては最小調査となるものではなかった. また, 計画を見たときに 2 手先まで最小だったものは 1 件しか存在しなかった. このことからエージェントの回答は, 対処を適用すべき箇所の絞り込みには効くが, 最小の調査計画における次の 1 手ではないものが大半である. なお調査妥当性と最小性に包含関係はなく, 最小性を満たした 13 件のうち 2 件は調査妥当性を満たしていなかった. これは間違った回答で言及した要素が, たまたま計画上の次の取得と一致した場合である. また, 実行可能性を満たさない回答は 115 件中 36 件あり, その時点で持っていない情報を手掛かりとして挙げてしまっていた.

表 3: エージェント（GPT-5.6 Terra）の評価結果

項目	事例 1	事例 2	事例 3	合計
回答数	104	8	3	115
調査妥当性	93 (89%)	7 (88%)	1 (33%)	101 (88%)
最小性	9 (8.7%)	3 (38%)	1 (33%)	13 (11%)
実行可能性	69 (66%)	7 (88%)	3 (100%)	79 (69%)
3 つをすべて満たす	3 (2.9%)	2 (25%)	1 (33%)	6 (5.2%)
計画 (2 手先) の最小性	1 (0.96%)	0 (0%)	0 (0%)	1 (0.87%)

5. 考察

5.1 タスク生成における対応目標設計の限界

表 2 に示したように今回の実験においてはタスクで使われた対応目標となるテクニックが事例ごとに一つになった. これはタスクで答えさせる計画の長さ $N = 2$ と, 対応目標にテクニックを加える際のフレームワーク上の制約に由来する. 後者は 3.3 節で述べたように, 完全にテクニックの情報がない状況でテクニックへの対応調査を行うことはできないため, 機械的にテクニックを認知するきっかけを決定したものであった. 具体的には D3FEND のアーティファクトによって定まる, テクニックの活動が残した痕跡や生成した対象が既知集合に含まれる調査計画経路の段階でのみ, 該当テクニックに対する対応目標をタスク生成すると条件づけている. しかしながら $N = 2$ の場合, このきっかけとなる調査要素から少なくとも 2 回の調査を行わなければ対処に必要な情報へ到達できないテクニックのみが, タスク生成可能なテクニックになってしまう. この条件を満たすためには複数のホストが事象に絡むなど複雑な事例で

© 2026 Information Processing Society of Japan

あり, かつ, 入力となる攻撃事例の中に関連する調査要素が複数存在することが言及されている必要がある. 一方, 公開されている攻撃事例では, 特に特徴的なテクニックについては調査要素が詳細に記載されやすいが, 多くのテクニックについてはそうではなく, 結果としてタスクに採用されるテクニックの少数化を招いている. そのためこのフレームワークによる生成可能性を広げるためには, 対応目標の与え方についてより柔軟な基準を採用するか, 調査要素をより自動的に補完できる仕組みが必要となる.

5.2 エージェントの傾向と最小性の限界

4.3 節の評価結果からエージェントの回答は有効であるが, 最小の調査計画とは一致していないことが読み取れる. 付録の表 A·5 に示すように今回のエージェントの回答では, 明らかにできると考えられる情報を可能な限り網羅的に取得しようとする回答が大半を占めた. これは最小性の観点からは非効率であるが, インシデント対応としては誤りとは言えない. 防御側の視点としては, どこまでが対処の範囲なのかは自明ではなく, 明らかにしていく必要があるためである. また, 今回の最小性判定には時間の概念が存在しておらず, 本来であれば速やかに完了する調査ならば実施のデメリットはほとんどないが, 本フレームワークでは重い調査と同じペナルティが課せられてしまう. そのため, エージェントの計画能力の有効性をより深く評価するためには, フレームワークのエッジに調査の時間の重みを追加するなどして, 時間の概念を導入するか, あるいは, 網羅性や全体像を明らかにした度合いといった別尺度を追加することが必要となる.

6. まとめ

本論文では, 低コストでエージェントのインシデント対応プランニング能力を評価可能なフレームワークを提案し, 実際にエージェント評価を実施した. 結果として, エージェントの調査計画の傾向を認識することができたが, より深く評価を行うためには, 調査数の最小性以外の指標の必要性も明らかになった.

参考文献

[1] Srinivas, S., Kirk, B., Zendejas, J., Espino, M., Boskovich, M., Bari, A., Dajani, K. and Alzahrani, N.: AI-augmented SOC: A survey of LLMs and agents for security automation, *Journal of Cybersecurity and Privacy*, Vol. 5, No. 4, p. 95 (2025).

[2] Lin, X., Zhang, J., Deng, G., Liu, T., Zhang, T., Guo, Q. and Chen, R.: Ircopilot: Automated incident response with large language models, *arXiv preprint arXiv:2505.20945* (2025).

[3] Hammar, K., Alpcan, T. and Lupu, E. C.: Incident Response Planning Using a Lightweight Large Language Model with Reduced Hallucination, *Network and Distributed System Security (NDSS) Symposium* (2026).

[4] Gao, Y., Hammar, K. and Li, T.: In-Context Autonomous Network Incident Response: An End-to-End Large Language Model Agent Approach, *Proceedings of the AAAI Symposium Series*, Vol. 9, No. 1, pp. 246–254 (2026).

[5] Tellache, A., Korba, A. A., Mokhtari, A., Moldovan, H. and Ghamri-Doudane, Y.: Advancing autonomous incident response: Leveraging LLMs and cyber threat intelligence, *GLOBECOM 2025-2025 IEEE Global Communications Conference*, IEEE, pp. 25–30 (2025).

[6] Strom, B. E., Applebaum, A., Miller, D. P., Nickels, K. C., Pennington, A. G. and Thomas, C. B.: Mitre att&ck: Design and philosophy, Technical report, Technical report (2018).

[7] Kaloroumakis, P. E. and Smith, M. J.: Toward a Knowledge Graph of Cybersecurity Countermeasures, Technical report, The MITRE Corporation (2021). `https://d3fend.mitre.org/resources/D3FEND.pdf` (Accessed: 2026-08-20).

[8] Microsoft Defender Security Research Team: Containing a Domain Compromise: How Predictive Shielding Shut Down Lateral Movement, Microsoft Security Blog, `https://www.microsoft.com/en-us/security/blog/2026/04/17/domain-compromise-predictive-shielding-shut-down-lateral-movement/` (2026). Published: 2026-04-17, Accessed: 2026-08-20.

[9] The DFIR Report: Apache ActiveMQ Exploit Leads to LockBit Ransomware, `https://thedfirreport.com/2026/02/23/apache-activemq-exploit-leads-to-lockbit-ransomware/` (2026). Published: 2026-02-23, Accessed: 2026-08-20.

[10] The DFIR Report: Cat's Got Your Files: Lynx Ransomware, `https://thedfirreport.com/2025/12/17/cats-got-your-files-lynx-ransomware/` (2025). Published: 2025-12-17, Accessed: 2026-08-20.

付　　録

A.1 調査要素の補完

3.1.1 項で述べたように, 情報グラフに必要な調査要素は必ずしも事例中に記載されない. そのため, 攻撃事例に明示された対象または事象から直接推定できるものに限り, 補完してグラフを作成する. 例えば, 被害端末から VPN を利用してイントラネットへアクセスしたことが記載されている場合,VPN の利用に用いられたアカウント, 接続元 IP アドレス, 接続元端末の識別情報, およびアクセス先を調査要素として補完できる. 事象の発生時刻についても同様に補完する. ログを絞り込む調査では, 対象を特定するために時刻の範囲が他の調査要素と併せて必要となるが, 一方で攻撃事例に具体的な日時が記載されていることは少ないためである. 具体的に補完対象とする調査要素について表 A·1 に記載する.

A.2 調査要素とタスク生成の具体例

A.2.1 タスク生成例

実際に生成された評価タスクを用いて, 始点の決定からタスク生成までを示す. 事例の設定を表 A·2 に示す.

© 2026 Information Processing Society of Japan

表 A·1: 暗黙的に補完する調査要素

区分	情報項目
端末	ホスト名・端末識別子
アカウント	ユーザ名・アカウント ID・メールアドレス・サービスアカウント名
プロセス	プロセス名・プロセス ID・コマンドライン・親プロセスの識別情報
ファイル	ファイル名・ファイルパス・ハッシュ値
ネットワーク	接続元または接続先の IP アドレス・ドメイン名・URL・ポート番号
ログ記録	ログ種別・イベント ID・レコード ID・ログの取得元
時刻	事象の発生時刻・調査対象とする時刻範囲

表 A·2: タスク生成例の設定

項目	設定
検知対象	インターネット公開アプリケーションの脆弱性を悪用した環境内への侵入
検知方針	ATT&CK の Detection Strategy に基づき, 公開アプリケーションへの要求, 関連するエラー, 侵害後のプロセス実行または外向き通信を相関して検知する
事例との対応	IIS サーバの侵害と,w3wp.exe を介した Web シェルの設置および実行が, 検知方針に対応する
始点集合 S	{IIS サーバ,w3wp.exe,IIS 上の Web シェル }. 検知方針と攻撃事例の対応から得られる調査要素
対応目標	Content Filtering と Web Shell（T1505.003）の組. Content Filtering は通信や入力を検査して不正なものを遮断する対処であり, Web Shell は Web サーバ上のスクリプトを遠隔操作の窓口として用いるテクニック
終点集合	{IIS 上の Web シェル,Exchange 上の Web シェル, Tomcat 上の Web シェル }. ただし, この例では IIS 上の Web シェルは始点集合に含まれている

始点集合に Web Shell によって設置された対象が含まれるため, この対応目標は検知直後から提示できる. 終点へ至る調査要素の取得関係を図 A·1 に示す. 太枠は終点となる調査要素を指す. この例では終点として必要な「IIS 上の Web シェル」は始点集合に含まれており, 調査を必要としない.

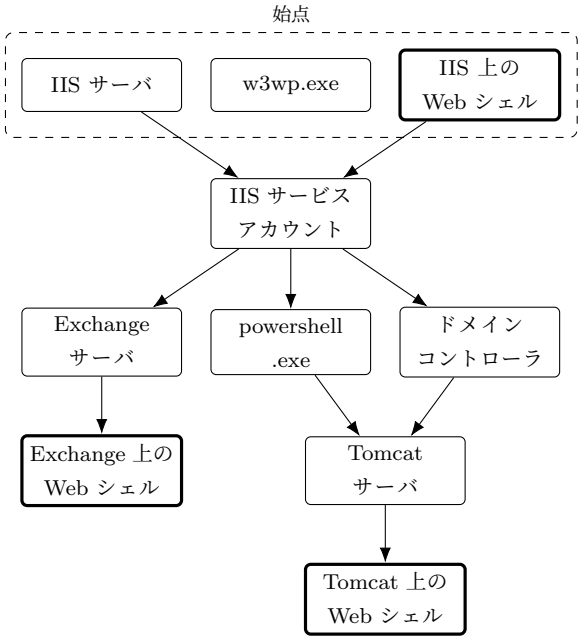


図 A·1: 調査要素の取得関係の例

図中の経路から, 次の既知集合をタスク生成時点として例示する.

$$K_0 = S, \qquad K_1 = K_0 \cup \{\text{IIS サービスアカウント }\},$$

$$K_2 = K_1 \cup \{\text{ ドメインコントローラ }\}.$$

K_1 からは複数の経路へ分岐するため, ここではドメインコントローラを取得して K_2 へ進む経路を選んだ. 各既知集合から次に取得できる調査要素とその前提条件を表 A·3 に示す. 各行がタスクにおける正解のもととなる.

また,K_0 をタスク生成時点としてエージェントに与える内容を表 A·4 に示す.

A.2.2 エージェントの回答の例（日本語訳）

表 A·4 のタスクに対する回答の 1 手目を表 A·5 に示す. 実行可能性は満たすが最小性は満たさない回答であり,4.3 節で述べた, 対処の対象を一度にまとめて明らかにしようとする回答にあたる.

この回答が明らかにしようとしているのは, 既に判明している Web シェルの関連情報を深掘りする調査になっており, 最小性における正解ではなく, 新たな情報を探すものでもなかった.2 手目も同様に,1 手目で得た特徴を用いて,Web シェル関連の通信が現れる全経路と遮断対象の範囲を確定しようとするもので, 対応目標よりも関連する情報の全体像を重視する傾向にある.

A.3 調査計画抽出の詳細

調査計画は, 情報グラフから候補を求め, 候補中の各取得

© 2026 Information Processing Society of Japan

表 A·3: 既知集合ごとの正解（日本語訳）

既知集合	次に取得する要素	手掛かり	前提集合
K_0	IIS サービスアカウント	IIS サーバ	なし
	IIS サービスアカウント	IIS 上の Web シェル	なし
K_1	Exchange サーバ	IIS サービスアカウント	なし
	powershell.exe	IIS サービスアカウント	IIS サーバ
	ドメインコントローラ	IIS サービスアカウント	IIS サーバ
K_2	Tomcat サーバ	ドメインコントローラ	なし

表 A·4: エージェントに提示するタスクの例（日本語訳）

項目	提示する内容
検知された事象	インターネットに面した IIS への攻撃が,w3wp.exe を介した Web シェルの設置および実行と, その後の HTTP/S 通信に結び付いている
現在までに判明している事実	インターネットに面した IIS サーバのファイルアップロードの脆弱性が悪用され,w3wp.exe を通じて Web シェルが設置・起動され, その後 HTTP/S 通信が行われた.IIS サーバからのパスワードスプレーにより, パスワードの使い回しを通じて少なくとも 14 台のサーバへのアクセスが得られた
対応目標	Content Filtering（対象の攻撃テクニック: Web Shell / T1505.003）
問い	判明している情報を用いて, 対応目標に必要な情報をできるだけ少ない調査で明らかにするため, 次に行うべき調査方針を 2 手示せ. 具体的なコマンドや製品操作ではなく, 調査方針を示すこと
回答の形式	各手について, 調査に利用する情報, 調査方針, 新たに明らかにしようとする情報, およびその情報を明らかにする目的の 4 項目を示す

が実際の調査として成立するかを確認することで抽出する. 確認によって取得条件が変わった場合は, その結果を反映して候補を作り直す. アルゴリズム 1 に, 一つの検知事象と一つの終点の組を対象とした手順を示す.

表 A·5: エージェントの回答の例（1 手目）

項目	回答
調査に利用する情報	インターネット公開 IIS サーバでファイルアップロード脆弱性が悪用された事実,w3wp.exe による Web シェルの導入・実行が確認されている事実,Web シェル実行後に HTTP/S 通信が発生した事実
調査方針	侵害された IIS サーバを起点に,Web シェルとして導入・実行されたファイルの実体と, その実行に対応する Web 要求を対応付けて確認する. ファイル内容・形式, 設置先, 要求 URI,HTTP メソッド, パラメータ, 要求本文, 応答, および該当要求の送信元を一つの活動系列として整理し, 通常のアプリケーション要求との差分を抽出する
新たに明らかにしようとする情報	Web シェルの利用を識別できる HTTP 要求・応答上の具体的な特徴（URI, パラメータ／本文, 固有文字列, エンコード形式, ファイル種別・配置を含む）
その情報を明らかにする目的	正規の業務通信を過度に遮断せず,Web シェルへのアクセスおよびアップロード／実行に結び付くコンテンツを,Content Filtering の検知・遮断条件へ転用できるようにするため

各調査方向の確認状況は, 疑似コード内で次の 3 状態として記録する.

- Unknown: まだ調査可能性を確認していない
- Investigable: 調査可能であり, 前提集合が判明している
- NonInvestigable: 調査不可能であり, 候補に使用しない

Judge(u, v) は, 調査要素 u を手掛かりとして v を取得できるかを判定し, 可否と前提集合を返す.MinPlans$(G, S, t, \text{state}, \text{sup})$ は, その時点までの確認結果を反映して候補計画を探索する.Investigable の方向は前提集合を満たす場合に使用し,NonInvestigable の方向は除外する. まだ確認していない方向については, 情報グラフにエッジがあることだけを候補生成の条件とする. この条件で,S から t へ至る取得数最小の候補計画をすべて返し, 候補が存在しない場合は $\varnothing$ を返す.

候補計画 $\Pi = (v_1, \ldots, v_m)$ の取得 v_j に関係する調査方向とは, 取得前の既知集合 K_{j-1} に含まれる要素 u から v_j へ向かう方向を指す. 候補が複数ある場合は, すべての候補についてこの方向を確認対象とする.「終点に最も近い方向」は, 候補計画の最も後の取得に関係する方向を意味する. 同じ位置に複数ある場合の選択は任意であり, 判定の順序だけに影響する.

© 2026 Information Processing Society of Japan

Algorithm 1 一つの検知事象と終点に対する調査計画の抽出

Require: 情報グラフ $G = (V, E)$，当該検知事象の始点となる調査要素の集合 $S \subseteq V$，終点となる調査要素 $t \in V$
Ensure: S から t に至る取得数最小の調査計画の集合，または失敗

if $t \in S$ **then**
  return $\{()\}$
end if
各調査方向の状態を Unknown に初期化する
loop
  $\mathcal{C} \leftarrow \mathrm{MinPlans}(G, S, t, \mathrm{state}, \mathrm{sup})$
  if $\mathcal{C} = \varnothing$ **then**
    return Failure
  end if
  $D \leftarrow \mathcal{C}$ の各取得に関係する状態が Unknown の調査方向
  if $D = \varnothing$ **then**
    return $\mathcal{C}$
  end if
  $(u, v) \leftarrow D$ のうち終点に最も近いもの
  $(\mathrm{ok}, s) \leftarrow \mathrm{Judge}(u, v)$
  if ok **then**
    $\mathrm{state}[u, v] \leftarrow$ Investigable
    $\mathrm{sup}[u, v] \leftarrow s$
  else
    $\mathrm{state}[u, v] \leftarrow$ NonInvestigable
  end if
end loop

$\mathrm{Judge}(u, v)$ の結果は, 次回の候補探索に次のように反映される.

- 前提なしで取得可能な場合, 候補中の取得条件は変わらない
- 追加の前提が必要な場合, その前提を既知とした後に限り当該方向を使用する
- 取得不可能な場合, 当該方向を候補から除外する

いずれの結果も候補を短くするものではない. 取得数最小の候補に関係する方向をすべて確認し, その候補が残った時点で, それらを最小の調査計画として返す. 候補がなくなった場合は, 当該の始点集合から終点へ至る調査計画を構成できないため失敗を返す. また, 反復ごとに一つの調査方向を確認し, 確認対象となる方向は有限であるため, この処理は有限回で終了する.

© 2026 Information Processing Society of Japan